

Security NFR's

Date	Editor	Changes applied
13/5/2026	Jim Hayes	

Identity and Access Management

NFR ID	NFR Name	Clear Requirement	CIS Controls	Domain
IAM-1	Unified Identity & MFA (Multi-Factor Authentication)	All users/admins must authenticate through centralised identity and use MFA. No legacy authentication	5,6	Identity
IAM-2	Least Privilege RBAC (Role-based access control)	Identities must have only the minimum permissions required for role. No standing admin roles	5,6	Identity
IAM-3	Privileged Access Management	All elevated permissions must use Privileged Identity management (PIM) with approval, justification, expiry	5	Identity
IAM-4	Access must be auto-provisioned/removed via joiner–mover–leaver processes	Access must be auto-provisioned/removed via current joiner – leaver-mover processes	5	Identity
IAM-5	Secure Service Identities	Apps and services must use managed Identity or secretless auth	5,6	Identity
IAM-6	Break-Glass Accounts	Break-glass accounts must use long strong passwords (≥16 characters), be monitored, and stored securely in Vault	5	Identity
IAM-7	Conditional Access	Conditional access should enforce device compliance, location, and risk-based rules	6	Identity
IAM-8	Identity Logging	Identity logs must be retained centrally for minimum 180 days and monitored for anomalies	8	Identity
IAM-9	Access Recertification	All privileged and high-risk access (admin roles, production access, break-glass accounts) must be recertified at least quarterly by the respective resource owners	6	Identity

Data Security

NFR ID	NFR Name	Clear Requirement	CIS Controls	Domain
Data-01	Data Classification	All data must be classified as per M&S data classification standard (Public/Internal/Confidential/Highly Confidential) with owners identified	3	Data
Data-02	Data Minimisation	Only necessary data may be collected or stored; unnecessary data must be removed	3	Data
Data-03	Encryption at Rest	All storage, DBs, and filesystems must have encryption enabled to AES-256	3	Data
Data-04	Encryption in Transit	TLS 1.2+ must be enforced for all traffic; no plaintext protocols allowed	3	Data
Data-05	Backup Security	Backups must be encrypted, immutable, geographically distributed, and regularly tested	10	Data
Data-06	Data Retention & Disposal	Data must be disposed of securely when no longer required	3	Data
Data-07	Sensitive Data Masking	Sensitive fields must be masked in logs, UI, analytics, and non-prod environments	3,16	Data
Data-08	Data Lineage & Ownership	Data flows must be documented end-to-end including system owners, consumers, and purpose	3	Data
Data-9	Secure File Handling	Files must be validated, scanned for malware, and stored in encrypted format	9,16	Data
Data-10	Data Sharing Controls	Data shared externally must have minimal scope, be encrypted in transit to TLS 1.2, and contractually governed	3,15	Data
Data-11	Use of Test Data	Non-production environments must not use production data unless explicitly approved and appropriately anonymised, or masked. Where production data is approved, security controls must be equivalent to production.	3,16	Data

Cloud Security

NFR ID	NFR Name	Clear Requirement	CIS Controls	Domain
Cloud-01	Azure Guardrails	Azure Policies must enforce logging, encryption, allowed locations, and tagging	4,7	Cloud
Cloud-02	Private Endpoints Only	PaaS services must use private endpoints; public network access disabled by default	12	Cloud
Cloud-03	Managed Identities	Azure workloads must use Managed Identity instead of secrets or credentials	5,6,16	Cloud
Cloud-04	Key Vault Hardening	Key Vault (KV) must enforce soft delete, purge protection, private access, secret rotation, and logging. Current RBAC must be enforced	3	Cloud
Cloud-05	Diagnostic Logging	All Azure services should have diagnostic logging enabled with minimum 180-day retention	8	Cloud
Cloud-06	Cloud Security Posture Management	Continuous scanning must detect misconfigurations; high/critical issues remediated in SLA	4,7	Cloud
Cloud-07	VM Hardening	VMs must use hardened images, patch automatically, and restrict remote admin access	4	Cloud
Cloud-08	Network Isolation	Workloads must run in segmented VNets; no open inbound ports; Network Security Groups (NSGs) must use deny-by-default, UDR and segmentation between production and lower environments	12	Cloud
Cloud-09	Logging for Admin Actions	Create/Update/Delete operations across Azure resources must be logged and monitored	8,17	Cloud
Cloud-10	Secure Containers in Cloud	AKS/container workloads must follow hardened baselines (non-root execution, restricted privileges)	4,7	Cloud
Cloud-11	Cloud Backup & DR	Cloud workloads hosting critical or regulated data must have defined and tested backup and disaster recovery strategies (RPO/RTO). Backups	11	Cloud

		must be encrypted, stored in a separate region or recovery vault, and restoration tested on annual basis.		
Cloud-12	Cloud Change Management & IaC	Infrastructure changes to cloud resources must be performed via approved Infrastructure-as-Code (IaC) or deployment pipelines where feasible, with code review, version control, and change traceability. Direct manual changes in production must be exceptional, logged, and reviewed.	4, 16	Cloud

Network Security

NFR ID	NFR Name	Clear Requirement	CIS Controls	Domain
Net-01	Network Segmentation	Networks must be segmented into zones (User, App, DB, Admin). All rules must be explicit allowlists; no any-any rules.	12,13	Network
Net-02	Ingress Firewall Control	All inbound traffic must go through approved firewalls with least-privilege rules	12	Network
Net-03	Egress Firewall Control	Outbound traffic must be controlled; no direct 0.0.0.0/0 egress from workloads	13	Network
Net-04	Secure Remote Admin	Admin access must use VPN/ZTNA with MFA. No public SSH/RDP allowed	12	Network
Net-05	DNS Security	All workloads must use approved DNS resolvers with logging and filtering enabled.	13	Network
Net-06	Network Monitoring	NSG flow logs and IDS/IPS telemetry must be enabled for critical networks	13	Network
Net-07	Zero Trust Network Access	Network access must use Zero Trust principles — verify user, device, and context	6,12	Network
Net-08	TLS Offload & Inspection	All outbound HTTPS traffic must support TLS inspection for threat detection	9,13	Network
Net-09	DDoS Protection	Internet-facing services must enable DDoS protection	13	Network
Net-10	Partner & S2S Links	Partner/site-to-site links must be encrypted, documented, reviewed annually, and restricted to required ports	15	Network
NET-11	Application Runtime Protection	All internet-facing web applications must be behind an enterprise-approved Web Application Firewall (WAF) with OWASP Top 10, bot protection, signature-based detection, anomaly detection, and geo/IP filtering enabled. WAF policies must be configured in prevention mode and deployed consistently across all environments handling production data	7,16,18	Network
NET-12	Network Time Synchronisation	All network infrastructure devices (firewalls, routers, switches, VPNs, WAFs, load balancers) must synchronise time with approved NTP sources to support accurate	8	Network

		logging, correlation, and forensics.		
Net-13	Network Device Hardening & Configuration Management	Firewalls, routers, switches, and load balancers must use secure baselines (no default passwords, management interfaces restricted, SSH only, secure SNMP, logging enabled). Configurations must be stored in version control, with changes peer-reviewed and backed up regularly.	4	Network

Application Security

NFR ID	NFR Name	Clear Requirement	CIS Controls	Domain
App-1	Secure SDLC	Every project must follow a Secure SDLC including threat modelling, secure design review, and code review	16	Application
App-2	Central Authentication	Apps must use managed identity. No local authentication	5,6	Application
App-3	Strong Session Management	Sessions must use secure cookies, short token lifetimes, and automatic expiry	16	Application
App-4	Input & Output Validation	All input must be validated and sanitised; output must be encoded to prevent injection	16	Application
App-5	Secure Error Handling	Error messages must not expose stack traces or internal system details	16	Application
App-6	Central Logging	Application logs must be centralised in SIEM (where appropriate) and must not contain sensitive data	8	Application
App-7	Dependency Management	Applications must maintain an SBOM and remediate vulnerable libraries within SLA	2,7	Application
App-8	Secrets Management	No secrets in repositories, config files, or pipelines. Apps must use Key Vault	3,4,16	Application
App-9	Secure File Uploads	File uploads must restrict file types via magic byte checks, enforce AV scanning, validate content, and store securely	9,16	Application
App-10	Hardening of Application Config	Debug mode must be disabled; verbose errors off; unused endpoints removed; secure headers enforced	4,16	Application
App-11	Business Logic Security	Critical workflows must include validation against misuse (e.g., anti-fraud checks, workflow integrity)	16	Application
App-12	Application Security Testing	All apps must undergo SAST, SCA, and where applicable DAST and penetration testing before go-live	7,16,18	Application
App-13	Application Inventory and service documentation	All Application components, including operating model must be documented along with a RACI	2,3,4,5,16,17	Application
App-14	Authorization Standard (RBAC/ABAC)	Applications must enforce least-privilege authorization using approved patterns (RBAC/ABAC). "Admin"	6, 16	Application

		capabilities must be separated from standard user flows.		
App-15	Security Patch & Configuration SLA	Application frameworks, runtimes, and OS/container base images must be patched within defined SLAs.	7,4	Application

API Security

NFR ID	NFR Name	Clear Requirement	CIS Controls	Domain
API-1	API Gateway Enforcement	All External and internal API's	12,16	API
API-2	API Authentication	APIs must use OAuth for user access and mTLS or managed identity for service-to-service access	5,6,16	API
API-3	API Authorisation	APIs must enforce least privilege scopes/roles. No broad " <i>admin</i> " scopes	6,16	API
API-4	Schema Validation	APIs must validate all requests using OpenAPI/JSON and reject unexpected input	16	API
API-5	Rate Limiting and Throttling	All APIs must implement rate limits	13	API
API-6	Input and Payload Security	APIs must reject oversized payloads, malformed JSON, and disallowed content types	16	API
API-7	Secure API Keys	API keys must never be hardcoded, must be rotated regularly, and must be stored securely (e.g., Key Vault). Tokens should be short lived.	3,5	API
API-8	API Logging	All API requests (successful and failed) must be logged with correlation IDs, without exposing sensitive data.	8,16	API
API-9	API Versioning	APIs must support versioning to prevent breaking changes and insecure legacy endpoints	16	API
API-10	API Inventory	All APIs must be catalogued with owner, consumers, data classification, and endpoints	1,2	API
API-11	Third-Party API Control	External integrations must use signed payloads, token-based auth, and data minimisation	15	API
API-12	API Security Testing	High-risk APIs must undergo periodic API-specific penetration testing (IDOR, BOLA, auth bypass)	18	API
API-13	Safe Error Handling	APIs must return generic error messages that do not leak sensitive information (stack traces, internal IDs, secrets). Detailed errors must be restricted to server-side logs only.	16	API
API-14	Sensitive Data Exposure Controls	APIs must not return sensitive fields unless explicitly required and authorized. Response payloads must adhere to data minimization based on data classification and consumer need.	3,6,16	API

CI/CD Security

NFR ID	NFR Name	Clear Requirement	CIS Controls	Domain
CICD-1	Pipeline Segregation	Dev, Test, and Prod pipelines must have gated progression to prevent direct deployment to production with distinct credentials to prevent direct deployment to production	4	CI/CD
CICD-2	Secure Build Agents	Self-hosted runners must be patched, hardened, and isolated; ephemeral runners preferred	4,7	CI/CD
CICD-3	Secrets	Secrets must not exist in pipeline variables or code; must use Key Vault or OIDC	3	CI/CD
CICD-4	SAST	SAST scanning must run on every pull request and block merge on Critical or High findings	7,16	CI/CD
CICD-5	SCA	Dependency scanning (SCA) must run continuously; Critical and High Vulnerabilities must be fixed within SLA	7	CI/CD
CICD-6	IaC	Terraform must be scanned before deployment; misconfigurations must be blocked	4,7	CI/CD
CICD-7	Artifact Integrity	Build artifacts must be signed; SBOM generated for every release	2,7,16	CI/CD
CICD-8	No Direct Production Deployments	Production deployments must be performed only via approved CI/CD pipelines with audit trails. Manual/CLI deployments are prohibited.	4	CI/CD
CICD-9	Branch Protection	Main and release branches must enforce approval workflows, code review, and security checks	4,16	CI/CD
CICD-10	Audit Logging	Pipeline runs, approvals, deployment events and pipeline policy configuration changes must be logged and retained for audit	8	CI/CD

Container and Kubernetes Security

NFR ID	NFR Name	Clear Requirement	CIS Controls	Domain
CONT-1	Image Scanning	All container images must be scanned at build time and runtime; critical vulnerabilities should fail the build and remediated within SLA	7	Containers
CONT-2	Non-Root Execution	Containers must run as non-root, with restricted privileges	4,7	Containers
CONT-3	Immutable Containers	Containers must be immutable; configuration must not be modified at runtime	4	Containers
CONT-4	Network Policies	Kubernetes network policies must block pod-to-pod communication unless explicitly allowed	12	Containers
CONT-5	Secrets in K8s	Secrets must be stored in Key Vault or K8s secrets encrypted by CMK; no secrets in config maps	3	Containers
CONT-6	Admission Control	Admission controllers must enforce allowed images, disallow privileged containers, and enforce security policies	4,16	Containers
CONT-7	Pod Security Controls	Apply Pod Security Standards (restricted level): no host network, no privileged escalation, no root fs write	4,7	Containers
CONT-8	HPA & Resource Quotas	Resource limits, requests, and quotas must be defined for all workloads to assist in the identification of suspicious or malicious workloads e.g. cryptomining	10	Containers
CONT-9	K8s RBAC	Kubernetes RBAC must enforce least privilege; admin access restricted to cluster ops only	5,6	Containers
CONT-10	Logging & Telemetry	Container stdout logs, Kube Audit logs, and network logs must be sanitised before being ingested in to a SIEM	8	Containers
CONT-11	Kubernetes Upgrade Policy	Clusters must run supported versions; patches applied within approved maintenance windows	4	Containers

Endpoint and Device Security

NFR ID	NFR Name	Clear Requirement	CIS Controls	Domain
ENDP-1	Device Compliance	All corporate devices must meet approved MDM/Intune compliance policies before accessing resources	1,12	Endpoints
ENDP-2	Disk Encryption	All laptops, desktops, and mobile devices must have full disk encryption enabled	3	Endpoints
ENDP-3	EDR Coverage	All endpoints must have an approved EDR/antimalware agent installed and active	10,13	Endpoints
ENDP-4	Local Admin Control	Local admin access must be removed for standard users; use elevation workflows only	5	Endpoints
ENDP-5	Secure Browser Config	Browsers must enforce safe browsing, anti-phishing, auto-update, and blocked risky extensions	9	Endpoints
ENDP-6	Email Protection	Email clients must enforce anti-malware, URL protection, attachment scanning, and anti-phishing controls	9	Endpoints
ENDP-7	Device Patch Compliance	Endpoints must apply OS and application patches within defined SLA (e.g., 14 days for critical)	7	Endpoints
ENDP-8	USB/Removable Media Control	Removable media must be restricted or monitored; encryption required for approved devices	3,9	Endpoints
ENDP-9	Mobile Device Security	Corporate mobile devices must use MDM, enforced PIN/biometrics, encryption, and remote wipe	12	Endpoints
ENDP-10	Secure Wi-Fi Usage	Devices must use approved corporate Wi-Fi or VPN; public/open Wi-Fi must require secure tunnelling	12	Endpoints

Infrastructure Security

NFR ID	NFR Name	Clear Requirement	CIS Controls	Domain
INF-01	Server Firmware & BIOS Hardening	All physical servers must enforce Secure Boot, BIOS/UEFI admin passwords, disable unused boot devices, and apply vendor-signed firmware only. Boot order must be locked. No unauthorised USB or PXE boot allowed		
INF-02	BMC / Out-of-Band (iDRAC/iLO) Security	All BMC interfaces (iLO, iDRAC, XClarity) must be placed on a dedicated management network, isolated from production, enforce MFA, disallow HTTP, and never be internet-accessible. Access must only be via authorised jump hosts		
INF-03	Standardised Server Build Baseline	All servers must be built using a hardened, approved baseline image with automated configuration management, drift detection, and patching		
INF-04	Server Logging & Audit	Servers must log all admin logins, privilege escalations, configuration changes, service start/stop, and security events. Logs must be centralised in SIEM with minimum 180-day retention		
INF-05	ESXi Host Lockdown Mode	ESXi hosts must run in Lockdown Mode. Direct console/SSH must be disabled except break-glass. Host firewall hardened		
INF-06	vCenter MFA & RBAC Enforcement	All admin access to vCenter must require MFA, use least-privilege roles, disable built-in admin accounts, and be reachable only from controlled jump host		
INF-07	VM Network Trust Controls	Promiscuous mode, forged transmits, and MAC address changes must be disabled unless explicitly approved		
INF-08	NSX Micro-Segmentation & Default Deny	Each workload must be micro-segmented behind NSX Distributed Firewall (DFW) with default-deny applied at east-west, with rules defined via application mapping		
INF-09	VMware Encryption (VM + vSAN)	VMs and vSAN must enforce encryption using enterprise-approved KMS with rotation and audit logs		
INF-10	VMware Patch Lifecycle Management	ESXi, vCenter and NSX must follow monthly patch scan,		

		quarterly patch application, and critical patching within 14 days		
INF-11	Network Device Hardening	Cisco devices must disable insecure services, enforce SSHv2, use secure SNMP, and encrypt all passwords/config		
INF-12	Secure Network Management Plane (Jump Host + MFA)	Management plane must require MFA, RBAC, IP filtering, and only allow access through hardened management jump hosts		
INF-13	Network Configuration Integrity & Backup	All network configs must be version-controlled, automatically backed up, and integrity checked		
INF-14	Layer 2 Threat Protection	Enable DHCP snooping, DAI, IP Source Guard, and BPDU guard across core/edge switches		
INF-15	Network Telemetry & Syslog	Cisco devices must forward admin logins, interface changes, routing updates, and security events to SIEM.		
INF-16	Network High Availability & Redundancy`	Critical networks must use redundant uplinks, stacked switches, redundant firewall nodes (HA pairs), and resilient routing		
INF-17	Backup Encryption TSM	All TSM backup data must be encrypted in flight and at rest. No plaintext data allowed.		
INF-18	Anti-Ransomware Storage Snapshots	Storage platforms must support immutable snapshots with enforced retention.		
INF-19	TSM Access Control & RBAC	TSM must enforce named accounts, MFA (if integrated), RBAC roles, and deny local admin logins		
INF-20	Backup Integrity, Immutability & Verification	Backups must support immutability, hashing, regular restore tests, and corruption checks		
INF-21	Infrastructure Backup Coverage	Backups must include: Backups must include: vCenter configuration, ESXi host profiles, NSX policies , Cisco configs, Firewall policies , Storage snapshots		
INF-22	TSM Patch & Version Currency	TSM servers, storage agents, and client backup agents must remain on supported versions and follow patch SLAs		
INF-23	Backup Air-Gapping or Logical Isolation	Backups must be stored in isolated networks/systems inaccessible to production identity paths		

INF-24	Certificate Lifecycle Management (Internal PKI)	All certificates (vCenter, ESXi, TSM, Cisco, appliances) must be issued via approved PKI with automated rotation (if possible) and expiry monitoring.		
INF-25	Storage & SAN Network Isolation	Storage/SAN networks must be isolated from compute and management networks with strict ACLs		
INF-26	vMotion Encryption	vMotion traffic must be encrypted with mandatory KMS-backed key management		
INF-27	API Hardening for vCenter/ESXi/NSX	All VMware APIs must enforce token-based auth, RBAC, and TLS1.2+.		
INF-28	Hypervisor Resource Isolation Limits	Resource limits (CPU/Memory/IO) must be configured to prevent noisy neighbour or crypto-mining workloads		
INF-29	Management Plane Segmentation Standard	All management interfaces (vCenter, ESXi, Cisco, firewalls, TSM, SAN, appliances) must reside in a dedicated management zone with deny-by-default rules		
INF-30	Network Access Control (NAC) Enforcement	Port-level NAC (802.1X or MAC-based) must be enabled across all user and server switch ports		
INF-31	DNSSEC & Internal DNS Integrity Controls	Internal DNS must support DNSSEC, signed records, and auditing to prevent DNS hijacking		
INF-32	Internal East-West IDS/IPS for DC Traffic	Critical DC segments must have IDS/IPS with signatures tailored for lateral movement detection		
INF-33	Log Volume Integrity & Tamper Detection for Infra Logs	Infrastructure-generated logs must be hash-verified and protected from log tampering		
INF-34	Privileged Workstation Requirement (PAWs) for Infra Admins	All engineers with infrastructure access must use Privileged Access Workstations (PAWs)		
INF-35	Break-Glass for Infrastructure Management Systems	Break-glass accounts for vCenter/ESXi/NSX/Cisco/TSM must be stored in vaults, monitored, rotated, and tested quarterly		
INF-36	Controlled Firmware Release Process	Firmware updates for servers, SAN, Cisco, VMware must follow signed binaries, vendor validation, and maintenance windows		

SaaS Security

NFR ID	NFR Name	Clear Requirement	CIS Controls	Domain
SAAS-1	SaaS MFA Enforcement	All SaaS applications must enforce MFA using Azure AD SSO or an approved identity provider and disable local accounts		
SAAS-2	Named Accounts Only	All SaaS applications must have named user accounts; shared accounts prohibited except for controlled break-glass.		
SAAS-3	Role-Based Access	SaaS access must be role-based and reviewed quarterly.		
SAAS-4	Separate Admin Accounts	Admins must have separate administrative accounts		
SAAS-5	TLS Enforcement	TLS 1.2+ required for all data in transit; insecure protocols disabled.		
SAAS-6	Encryption at Rest	SaaS must encrypt data at rest using industry-standard algorithms (AES-256)		
SAAS-7	Admin Network Restrictions	Admin Access should be restricted via IP allow-listing or conditional access		
SAAS-8	Secure API Auth	SaaS APIs must require scoped, authenticated, authorised short-lived tokens		
SAAS-9	SaaS Secrets Management	API keys and secrets must be stored in a vault and rotated regularly. All API keys in use must be reviewed quarterly.		
SAAS-10	Scoped API Tokens	API tokens must be least-privileged, revocable, and rotatable		
SAAS-11	Vendor Security Documentation	Vendors must provide SOC2/ISO27001/pen test summaries		
SAAS-12	Automated User Provisioning	SaaS must support SCIM/JIT or IdP-driven provisioning/deprovisioning		
SAAS-13	Vendor Application Security	Vendor must operate a formal Application Security programme that ensures secure development, continuous vulnerability management throughout the product lifecycle		
SAAS-14	Vendor Vulnerability Management	Vendor must operate a formal vulnerability scanning and patching programme		
SAAS-15	Environment Separation	Prod and non-prod environments must be logically separated		
SAAS-16	SaaS Least Privilege	Admin roles in SaaS systems must be restricted to designated administrators only; no broad admin access		

SAAS-17	Session Management	SaaS admin UI must enforce session timeout and require re-auth for sensitive actions		
SAAS-18	SaaS Logging	SaaS apps must enable logging of admin changes, authentication events, and security configurations		
SAAS-19	Browser Security Controls	CSP, XSS protection, anti-clickjacking headers must be in place		
SAAS-20	Email Authentication	DMARC, DKIM, and SPF must be correctly configured for all email domains		
SAAS-21	External Sharing Restrictions	SharePoint/OneDrive/Teams external sharing must be restricted to approved domains/users		
SAAS-22	Data Residency Governance	SaaS applications must store data within approved geographic regions		
SAAS-23	SaaS Backup Recovery	Critical SaaS systems must have vendor-provided backup or data export/restore capabilities		
SAAS-24	Third-Party App Control	OAuth-connected third-party apps must be reviewed and approved before access is granted		
SAAS-25	Sub-processor Transparency	Vendor must disclose data shared with sub-processors		
SAAS-26	Tenant Hardening	SaaS tenants must enforce secure defaults: disable legacy auth, restrict anonymous access, enforce session controls		
SAAS-27	SaaS Data Loss Controls	SaaS applications must enforce DLP rules on data downloads, sharing, and external transfers		
SAAS-28	Account Audit	SaaS accounts and associated permissions must be reviewed on a quarterly basis as a minimum.		

Supplier and Third-Party Security

NFR ID	NFR Name	Clear Requirement	CIS Controls	Domain
SUP-1	Supplier Due Diligence	All vendors must undergo security assessment before onboarding	15	Supplier
SUP-2	Minimum Security Requirements	Suppliers must meet minimum controls for IAM, encryption, logging, and data protection. Vendors must provide a penetration test report where requested.	15	Supplier
SUP-3	Secure API Integration	External integrations must use token-based auth, mTLS, and minimal data sharing	15	Supplier
SUP-4	Data Processing Agreements	Data sharing with suppliers must be covered by formal data processing agreements	15	Supplier
SUP-5	Third-Party Risk Monitoring	Supplier posture must be reviewed annually for compliance and incidents	15	Supplier
SUP-6	Vendor Access Control	Suppliers must use named accounts; no shared or generic accounts allowed	5,6	Supplier
SUP-7	Secure File Transfer	Third-party file transfers must use encrypted channels and approved protocols only	12	Supplier
SUP-8	Supplier Termination	Supplier access must be removed and data deleted/returned upon contract termination	15	Supplier
SUP-9	Supplier API	Decommission any API integrations and remove vendor from current communication channels	15	Supplier

AI & ML Security

NFR ID	NFR Name	Clear Requirement	CIS Controls	Domain
AI-1	Model Versioning	ML models must be versioned with full traceability of training data and parameters	2,16	AI/ML
AI-2	Model Integrity & Signing	Models must be signed and verified before deployment to prevent tampering	2,16	AI/ML
AI-3	Dataset Governance	Training datasets must follow classification, retention, and ownership rules	3	AI/ML
AI-4	Input Validation for ML	ML endpoints must validate input to prevent poisoning or oversized payload attacks	16	AI/ML
AI-5	Model Access Control	ML endpoints must enforce authentication and authorisation to restrict queries	5,6	AI/ML
AI-6	Prompt Injection Controls	ML model to implement Prompt Injection Controls	16	AI/ML
AI-7	Model Output Filtering	Responses from ML systems must be filtered to prevent sensitive data leakage	3,16	AI/ML
AI-8	Adversarial Testing	ML models must undergo periodic adversarial testing (evasion, extraction, poisoning)	18	AI/ML

Logging, Monitoring and Alerting

NFR ID	NFR Name	Clear Requirement	CIS Controls	Domain
LOG-01	Centralised Logging	Systems with Sensitive data or support critical business processes must send logs to SIEM with minimum 180 day retention	8	Logging, Monitoring & Alerting
LOG-02	Admin Activity Logging	All admin actions (create/update/delete) must be logged and forwarded to SIEM	8,17	Logging, Monitoring & Alerting
LOG-03	Access Logging	All authentication/authorisation events must be logged and monitored	8	Logging, Monitoring & Alerting
LOG-04	Error & Exception Logging	Errors must be logged without exposing sensitive data	16	Logging, Monitoring & Alerting
LOG-05	Log Integrity	Logs must be tamper-resistant, immutable	8,10	Logging, Monitoring & Alerting
LOG-06	Alerting Use Cases	Key use cases (privilege escalation, failed logins, data exfiltration) must trigger alerts	17	Logging, Monitoring & Alerting
LOG-07	Time Sync	All systems must use approved time sources to ensure consistent timestamps	8	Logging, Monitoring & Alerting
LOG-08	API Logging	API gateway logs (requests, failures, throttling) must be enabled and centralised	8,13	Logging, Monitoring & Alerting
LOG-09	Log Access Control	Access to logs must be restricted to approved users only	5	Logging, Monitoring & Alerting

OT Security

ID	Name	Requirement	CIS Control	Domain
OT-01	Controlled IT/OT Boundary	All IT/cloud ↔ OT communication must traverse a controlled, inspected boundary enforcing authentication and policy.	CIS 13	Architecture
OT-02	Zone-Based Segmentation	OT environments must be segmented into zones with strictly controlled conduits.	CIS 13	Architecture
OT-03	Default Deny Network Model	All OT communication must follow explicit allowlisting (deny by default).	CIS 13	Network Security
OT-04	Controller Isolation	PLCs, RTUs, and robot controllers must be isolated from IT and non-critical OT systems.	CIS 13	Control Layer
OT-05	Cell/Process Isolation	Production cells or process areas must be segmented to prevent lateral movement.	CIS 13	Control Layer
OT-06	Protocol Allowlisting	Only explicitly approved industrial protocols and ports must be permitted.	CIS 12	Network Security
OT-07	No Internet Exposure	OT assets must not be directly accessible from the internet.	CIS 4	Exposure Management
OT-08	Data Flow Enforcement	Documented OT data flows must be technically enforced.	CIS 13	Architecture
OT-09	Brokered Remote Access	All remote access must go through controlled jump hosts or ZTNA with MFA.	CIS 6	Identity & Access
OT-10	Time-Bound Access	Privileged and remote access must be time-limited and automatically revoked.	CIS 6	Identity & Access
OT-11	Vendor Access Control	Third-party access must be approved, monitored, and non-persistent.	CIS 15	Third-Party Risk
OT-12	Privileged Access Restriction	Administrative access must be restricted and controlled.	CIS 6	Identity & Access
OT-13	Default Credential Removal	Default credentials must not exist on OT assets.	CIS 5	Identity & Access
OT-14	Least Privilege Enforcement	Access must be limited to the minimum required for the role.	CIS 6	Identity & Access

OT-15	Session Monitoring	All privileged and remote sessions must be logged and monitored.	CIS 8	Monitoring
OT-16	Engineering Workstation Isolation	Engineering workstations must be isolated and restricted from general IT and internet access.	CIS 4	Endpoint Security
OT-17	Controlled Engineering Access	Only authorised users may modify PLC logic, robot programs, or SCADA configs.	CIS 6	Control Integrity
OT-18	Logic Change Governance	All logic/configuration changes must follow controlled and auditable processes.	CIS 4	Change Management
OT-19	Logic Integrity Protection	Controller and automation logic must be protected from unauthorised modification.	CIS 3	Control Integrity
OT-20	Controller Hardening	PLCs and controllers must be hardened (disable unused services, restrict programming).	CIS 4	Control Layer
OT-21	SCADA/HMI Hardening	SCADA and HMI systems must follow secure configuration baselines.	CIS 4	SCADA / HMI
OT-22	Secure Protocol Usage	Secure variants of industrial protocols must be used where supported.	CIS 12	Network Security
OT-23	Asset Inventory	A complete inventory of all OT assets must be maintained.	CIS 1	Asset Management
OT-24	Firmware & Version Tracking	Firmware and software versions must be tracked for all OT devices.	CIS 7	Vulnerability Management
OT-25	Passive Asset Discovery	OT asset discovery must use passive techniques only.	CIS 1	Asset Management
OT-26	OT Network Monitoring	OT networks must be monitored using passive detection techniques.	CIS 13	Monitoring
OT-27	Command-Level Visibility	Monitoring must include visibility of control commands and changes.	CIS 8	Monitoring
OT-28	Centralised Logging	Security logs must be centrally collected and retained.	CIS 8	Monitoring
OT-29	Time Synchronisation	OT systems must use a consistent and trusted time source.	CIS 8	Monitoring
OT-30	Vulnerability Management	OT vulnerabilities must be identified, assessed, and tracked.	CIS 7	Vulnerability Management

OT-31	Compensating Controls	Where patching is not possible, alternative controls must be implemented.	CIS 7	Vulnerability Management
OT-32	Risk-Based Patching	All Assets must be frequently and regularly patched	CIS 7	Vulnerability Management
OT-33	Offline Backups	Critical OT configurations and logic must be backed up offline.	CIS 11	Recovery
OT-34	Backup Protection	Backups must be protected from unauthorised modification or deletion.	CIS 11	Recovery
OT-35	Recovery Validation	OT recovery processes must be tested periodically.	CIS 11	Recovery
OT-36	Secure Data Transfer	Transfer of OT data and configurations must be controlled and validated.	CIS 3	Data Protection
OT-37	Historian/Data Access Control	Access to OT data repositories must be restricted and monitored.	CIS 3	Data Protection
OT-38	Secure Integration Pattern	OT integrations must use mediated, authenticated interfaces (no direct trust).	CIS 16	Application Security
OT-39	Firmware/Software Integrity	OT firmware and software must be validated before deployment.	CIS 2	Supply Chain
OT-40	Incident Detection Capability	OT environments must support detection of unauthorised activity and abnormal behaviour.	CIS 17	Detection & Response
OT-41	East-West Traffic Control	Lateral movement within OT zones must be restricted and monitored.	CIS 13	Network Security
OT-42	Controller Programming Mode Control	Programming mode on PLCs/controllers must be restricted to authorised sessions only.	CIS 6	Control Layer
OT-43	Command Authorisation	High-risk control commands must require explicit authorisation beyond network access.	CIS 6	Control Integrity
OT-44	Configuration Drift Detection	Deviations from approved OT configurations must be detected and alerted.	CIS 4	Configuration
OT-45	Segmentation Validation	Segmentation rules must be continuously validated against intended design.	CIS 13	Network Security

